

CVEs más relevantes de la semana

Del 17/03/2026 al 24/03/2026

Porque el primer paso para defender es conocer las amenazas.



CVE-2026-3856

Descripción: IBM Db2 Recovery Expert for Linux, UNIX and Windows 5.5 IF 2 could allow an attacker to modify or corrupt data due to an insecure mechanism used for verifying the integrity of the data during transmission.

CVSS: 5.3 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N

Tipo: CWE-353

Tecnología: No especificado

Publicado el: 2026-03-17



CVE-2026-27459

Descripción: pyOpenSSL is a Python wrapper around the OpenSSL library. Starting in version 22.0.0 and prior to version 26.0.0, if a user provided callback to `set_cookie_generate_callback` returned a cookie value greater than 256 bytes, pyOpenSSL would overflow an OpenSSL provided buffer. Starting in version 26.0.0, cookie values that are too long are now rejected.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-120

Tecnología: No especificado

Publicado el: 2026-03-18



CVE-2026-22171

Descripción: OpenClaw versions prior to 2026.2.19 contain a path traversal vulnerability in the Feishu media download flow where untrusted media keys are interpolated directly into temporary file paths in extensions/feishu/src/media.ts. An attacker who can control Feishu media key values returned to the client can use traversal segments to escape os.tmpdir() and write arbitrary files within the OpenClaw pro...

CVSS: 8.2 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-03-18



CVE-2026-28500

Descripción: Open Neural Network Exchange (ONNX) is an open standard for machine learning interoperability. In versions up to and including 1.20.1, a security control bypass exists in `onnx.hub.load()` due to improper logic in the repository trust verification mechanism. While the function is designed to warn users when loading models from non-official sources, the use of the `silent=True` parameter completely ...

CVSS: 8.6 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:N/A:N

Tipo: CWE-345

Tecnología: No especificado

Publicado el: 2026-03-18



CVE-2026-2991

Descripción: The KiviCare – Clinic & Patient Management System (EHR) plugin for WordPress is vulnerable to Authentication Bypass in all versions up to, and including, 4.1.2. This is due to the `patientSocialLogin()` function not verifying the social provider access token before authenticating a user. This makes it possible for unauthenticated attackers to log in as any patient registered on the system by pr...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-03-18



CVE-2026-32611

Descripción: Glances is an open-source system cross-platform monitoring tool. The GHSA-x46r fix (commit 39161f0) addressed SQL injection in the TimescaleDB export module by converting all SQL operations to use parameterized queries and `psycopg.sql` composable objects. However, the DuckDB export module (`glances/exports/glances\_duckdb/\_\_init\_\_.py`) was not included in this fix and contains the same class of...

CVSS: 7.0 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:L/A:L

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-03-18



CVE-2026-31966

Descripción: HTSlib is a library for reading and writing bioinformatics file formats. CRAM is a compressed format which stores DNA sequence alignment data. As one method of removing redundant data, CRAM uses reference-based compression so that instead of storing the full sequence for each alignment record it stores a location in an external reference sequence along with a list of differences to the referenc...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:H

Tipo: CWE-125

Tecnología: No especificado

Publicado el: 2026-03-18



CVE-2026-31967

Descripción: HTSlib is a library for reading and writing bioinformatics file formats. CRAM is a compressed format which stores DNA sequence alignment data. In the `'cram_decode_slice()'` function called while reading CRAM records, the value of the mate reference id field was not validated. Later use of this value, for example when converting the data to SAM format, could result in the out of bounds array read...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:H

Tipo: CWE-125

Tecnología: No especificado

Publicado el: 2026-03-18



CVE-2026-25873

Descripción: OmniGen2-RL contains an unauthenticated remote code execution vulnerability in the reward server component that allows remote attackers to execute arbitrary commands by sending malicious HTTP POST requests. Attackers can exploit insecure pickle deserialization of request bodies to achieve code execution on the host system running the exposed service.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-502

Tecnología: No especificado

Publicado el: 2026-03-18



CVE-2026-31972

Descripción: SAMtools is a program for reading, manipulating and writing bioinformatics file formats. The 'mpileup' command outputs DNA sequences that have been aligned against a known reference. On each output line it writes the reference position, optionally the reference DNA base at that position (obtained from a separate file) and all of the DNA bases that aligned to that position. As the output is orde...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-416

Tecnología: No especificado

Publicado el: 2026-03-18



CVE-2025-15031

Descripción: A vulnerability in MLflow's pyfunc extraction process allows for arbitrary file writes due to improper handling of tar archive entries. Specifically, the use of `tarfile.extractall` without path validation enables crafted tar.gz files containing `..` or absolute paths to escape the intended extraction directory. This issue affects the latest version of MLflow and poses a high/critical risk in s...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-03-18



CVE-2026-31998

Descripción: OpenClaw versions 2026.2.22 and 2026.2.23 contain an authorization bypass vulnerability in the synology-chat channel plugin where dmPolicy set to allowlist with empty allowedUserIds fails open. Attackers with Synology sender access can bypass authorization checks and trigger unauthorized agent dispatch and downstream tool actions.

CVSS: 7.0 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:H/A:L

Tipo: CWE-863

Tecnología: No especificado

Publicado el: 2026-03-19



CVE-2006-10003

Descripción: XML::Parser versions through 2.47 for Perl has an off-by-one heap buffer overflow in st_serial_stack.

In the case $(stackptr == stacksize - 1)$, the stack will NOT be expanded. Then the new value will be written at location $(++stackptr)$, which equals $stacksize$ and therefore falls just outside the allocated buffer.

The bug can be observed when parsing an XML file with very deep element nesting

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-122

Tecnología: No especificado

Publicado el: 2026-03-19



CVE-2026-26137

Descripción: Server-side request forgery (ssrf) in Microsoft 365 Copilot's Business Chat allows an authorized attacker to elevate privileges over a network.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:L

Tipo: CWE-918

Tecnología: No especificado

Publicado el: 2026-03-19



CVE-2026-32169

Descripción: Server-side request forgery (ssrf) in Azure Cloud Shell allows an unauthorized attacker to elevate privileges over a network.

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-918

Tecnología: No especificado

Publicado el: 2026-03-19



CVE-2026-32191

Descripción: Improper neutralization of special elements used in an os command ('os command injection') in Microsoft Bing Images allows an unauthorized attacker to execute code over a network.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-03-19



CVE-2026-32749

Descripción: SiYuan is a personal knowledge management system. In versions 3.6.0 and below, POST /api/import/importSY and POST /api/import/importZipMd write uploaded archives to a path derived from the multipart filename field without sanitization, allowing an admin to write files to arbitrary locations outside the temp directory - including system paths that enable RCE. This can lead to aata destruction by...

CVSS: 7.6 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:L/I:H/A:N

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-03-19



CVE-2026-30871

Descripción: OpenWrt Project is a Linux operating system targeting embedded devices. In versions prior to 24.10.6 and 25.12.1, the mdns daemon has a Stack-based Buffer Overflow vulnerability in the parse_question function. The issue is triggered by PTR queries for reverse DNS domains (.in-addr.arpa and .ip6.arpa). DNS packets received on UDP port 5353 are expanded by dn_expand into an 8096-byte global buff...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-121

Tecnología: No especificado

Publicado el: 2026-03-19



CVE-2026-30872

Descripción: OpenWrt Project is a Linux operating system targeting embedded devices. In versions prior to 24.10.6 and 25.12.1, the mdns daemon has a Stack-based Buffer Overflow vulnerability in the match_ipv6_addresses function, triggered when processing PTR queries for IPv6 reverse DNS domains (.ip6.arpa) received via multicast DNS on UDP port 5353. During processing, the domain name from name_buffer is co...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-121

Tecnología: No especificado

Publicado el: 2026-03-19



CVE-2026-32038

Descripción: OpenClaw before 2026.2.24 contains a sandbox network isolation bypass vulnerability that allows trusted operators to join another container's network namespace. Attackers can configure the `docker.network` parameter with `container:<id>` values to reach services in target container namespaces and bypass network hardening controls.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-284

Tecnología: No especificado

Publicado el: 2026-03-19



CVE-2026-32194

Descripción: Improper neutralization of special elements used in a command ('command injection') in Microsoft Bing Images allows an unauthorized attacker to execute code over a network.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-03-19



CVE-2026-32751

Descripción: SiYuan is a personal knowledge management system. In versions 3.6.0 and below, the mobile file tree (MobileFiles.ts) renders notebook names via innerHTML without HTML escaping when processing renamenotebook WebSocket events. The desktop version (Files.ts) properly uses escapeHtml() for the same operation. An authenticated user who can rename notebooks can inject arbitrary HTML/JavaScript that e...

CVSS: 9.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:C/C:H/I:H/A:H

Tipo: CWE-79

Tecnología: No especificado

Publicado el: 2026-03-19



CVE-2026-32754

Descripción: FreeScout is a free help desk and shared inbox built with PHP's Laravel framework. Versions 1.8.208 and below are vulnerable to Stored Cross-Site Scripting (XSS) through FreeScout's email notification templates. Incoming email bodies are stored in the database without sanitization and rendered unescaped in outgoing email notifications using Blade's raw output syntax {!! \$thread->body !!}. An un...

CVSS: 9.3 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:N

Tipo: CWE-79

Tecnología: No especificado

Publicado el: 2026-03-19



CVE-2026-32760

Descripción: File Browser is a file managing interface for uploading, deleting, previewing, renaming, and editing files within a specified directory. In versions 2.61.2 and below, any unauthenticated visitor can register a full administrator account when self-registration (signup = true) is enabled and the default user permissions have perm.admin = true. The signup handler blindly applies all default settin...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-269

Tecnología: No especificado

Publicado el: 2026-03-20



CVE-2026-33289

Descripción: SuiteCRM is an open-source, enterprise-ready Customer Relationship Management (CRM) software application. Prior to versions 7.15.1 and 8.9.3, an LDAP Injection vulnerability exists in the SuiteCRM authentication flow. The application fails to properly sanitize user-supplied input before embedding it into the LDAP search filter. By injecting LDAP control characters, an unauthenticated attacker c...

CVSS: 8.8 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-90

Tecnología: No especificado

Publicado el: 2026-03-20



CVE-2026-32945

Descripción: PJSIP is a free and open source multimedia communication library written in C. Versions 2.16 and below have a Heap-based Buffer Overflow vulnerability in the DNS parser's name length handler. This impacts applications using PJSIP's built-in DNS resolver, such as those configured with `pjsua_config.nameserver` or `UaConfig.nameserver` in PJSUA/PJSUA2. It does not affect users who rely on the OS resolv...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-122

Tecnología: No especificado

Publicado el: 2026-03-20



CVE-2026-4038

Descripción: The Aimogen Pro plugin for WordPress is vulnerable to Arbitrary Function Call that can lead to privilege escalation due to a missing capability check on the 'aiomatic_call_ai_function_realtime' function in all versions up to, and including, 2.7.5. This makes it possible for unauthenticated attackers to call arbitrary WordPress functions such as 'update_option' to update the default role for reg...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-862

Tecnología: No especificado

Publicado el: 2026-03-20



CVE-2026-33024

Descripción: AVideo is a video-sharing Platform. Versions prior to 8.0 contain a Server-Side Request Forgery vulnerability (CWE-918) in the public thumbnail endpoints getImage.php and getImageMP4.php. Both endpoints accept a base64Url GET parameter, base64-decode it, and pass the resulting URL to ffmpeg as an input source without any authentication requirement. The prior validation only checked that the URL...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-918

Tecnología: No especificado

Publicado el: 2026-03-20



CVE-2026-4469

Descripción: A vulnerability was identified in itsourcecode Online Frozen Foods Ordering System 1.0. Affected by this vulnerability is an unknown functionality of the file `/admin/admin_edit_menu_action.php`. Such manipulation of the argument `product_name` leads to sql injection. The attack may be performed from remote. The exploit is publicly available and might be used.

CVSS: 4.7 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:U/C:L/I:L/A:L

Tipo: CWE-74

Tecnología: No especificado

Publicado el: 2026-03-20



CVE-2026-4470

Descripción: A security flaw has been discovered in itsourcecode Online Frozen Foods Ordering System 1.0. Affected by this issue is some unknown functionality of the file /admin/admin_edit_menu.php. Performing a manipulation of the argument product_name results in sql injection. It is possible to initiate the attack remotely. The exploit has been released to the public and may be used for attacks.

CVSS: 4.7 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:U/C:L/I:L/A:L

Tipo: CWE-74

Tecnología: No especificado

Publicado el: 2026-03-20



CVE-2026-4471

Descripción: A weakness has been identified in itsourcecode Online Frozen Foods Ordering System 1.0. This affects an unknown part of the file /admin/admin_edit_employee.php. Executing a manipulation of the argument First_Name can lead to sql injection. It is possible to launch the attack remotely. The exploit has been made available to the public and could be used for attacks.

CVSS: 4.7 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:U/C:L/I:L/A:L

Tipo: CWE-74

Tecnología: No especificado

Publicado el: 2026-03-20



CVE-2026-4472

Descripción: A security vulnerability has been detected in itsourcecode Online Frozen Foods Ordering System 1.0. This vulnerability affects unknown code of the file /admin/admin_edit_supplier.php. The manipulation of the argument Supplier_Name leads to sql injection. The attack can be initiated remotely. The exploit has been disclosed publicly and may be used.

CVSS: 6.3 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:L

Tipo: CWE-74

Tecnología: No especificado

Publicado el: 2026-03-20



CVE-2026-4473

Descripción: A vulnerability was detected in itsourcecode Online Doctor Appointment System 1.0. This issue affects some unknown processing of the file /admin/appointment_action.php. The manipulation of the argument appointment_id results in sql injection. The attack can be launched remotely. The exploit is now public and may be used.

CVSS: 4.7 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:U/C:L/I:L/A:L

Tipo: CWE-74

Tecnología: No especificado

Publicado el: 2026-03-20



CVE-2026-33054

Descripción: Mesop is a Python-based UI framework that allows users to build web applications. Versions 1.2.2 and below contain a Path Traversal vulnerability that allows any user supplying an untrusted state_token through the UI stream payload to arbitrarily target files on the disk under the standard file-based runtime backend. This can result in application denial of service (via crash loops when reading...

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-03-20



CVE-2026-33066

Descripción: SiYuan is a personal knowledge management system. In versions 3.6.0 and below, the backend renderREADME function uses `lute.New()` without calling `SetSanitize(true)`, allowing raw HTML embedded in Markdown to pass through unmodified. The frontend then assigns the rendered HTML to `innerHTML` without any additional sanitization. A malicious package author can embed arbitrary JavaScript in their README...

CVSS: 9.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:C/C:H/I:H/A:H

Tipo: CWE-79

Tecnología: No especificado

Publicado el: 2026-03-20



CVE-2026-33067

Descripción: SiYuan is a personal knowledge management system. Versions 3.6.0 and below render package metadata fields (displayName, description) using template literals without HTML escaping. A malicious package author can inject arbitrary HTML/JavaScript into these fields, which executes automatically when any user browses the Bazaar page. Because SiYuan's Electron configuration enables nodeIntegration: t...

CVSS: 9.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:C/C:H/I:H/A:H

Tipo: CWE-79

Tecnología: No especificado

Publicado el: 2026-03-20



CVE-2026-33128

Descripción: H3 is a minimal H(TTP) framework. In versions prior to 1.15.6 and between 2.0.0 through 2.0.1-rc.14, createEventStream is vulnerable to Server-Sent Events (SSE) injection due to missing newline sanitization in formatEventStreamMessage() and formatEventStreamComment(). An attacker who controls any part of an SSE message field (id, event, data, or comment) can inject arbitrary SSE events to conne...

CVSS: 7.5 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:C/C:L/I:H/A:N

Tipo: CWE-93

Tecnología: No especificado

Publicado el: 2026-03-20



CVE-2026-33131

Descripción: H3 is a minimal H(TTP) framework. Versions 2.0.0-0 through 2.0.1-rc.14 contain a Host header spoofing vulnerability in the NodeRequestUrl (which extends FastURL) which allows middleware bypass. When event.url, event.url.hostname, or event.url._url is accessed, such as in a logging middleware, the _url getter constructs a URL from untrusted data, including the user-controlled Host header. Becaus...

CVSS: 7.4 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-290

Tecnología: No especificado

Publicado el: 2026-03-20



CVE-2026-22172

Descripción: OpenClaw versions prior to 2026.3.12 contain an authorization bypass vulnerability in the WebSocket connect path that allows shared-token or password-authenticated connections to self-declare elevated scopes without server-side binding.

Attackers can exploit this logic flaw to present unauthorized scopes such as operator.admin and perform admin-only gateway operations.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-862

Tecnología: No especificado

Publicado el: 2026-03-20



CVE-2026-3584

Descripción: The Kali Forms plugin for WordPress is vulnerable to Remote Code Execution in all versions up to, and including, 2.4.9 via the 'form_process' function. This is due to the 'prepare_post_data' function mapping user-supplied keys directly into internal placeholder storage, combined with the use of 'call_user_func' on these placeholder values. This makes it possible for unauthenticated attackers to...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-03-20



CVE-2026-33228

Descripción: flattened is a circular JSON parser. Prior to version 3.4.2, the parse() function in flattened can use attacker-controlled string values from the parsed JSON as direct array index keys, without validating that they are numeric. Since the internal input buffer is a JavaScript Array, accessing it with the key "__proto__" returns Array.prototype via the inherited getter. This object is then treated as...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-1321

Tecnología: No especificado

Publicado el: 2026-03-20



CVE-2026-32052

Descripción: OpenClaw versions prior to 2026.2.24 contain a command injection vulnerability in the system.run shell-wrapper that allows attackers to execute hidden commands by injecting positional argv carriers after inline shell payloads. Attackers can craft misleading approval text while executing arbitrary commands through trailing positional arguments that bypass display context validation.

CVSS: 6.4 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:R/S:U/C:N/I:H/A:H

Tipo: CWE-436

Tecnología: No especificado

Publicado el: 2026-03-21



CVE-2026-32056

Descripción: OpenClaw versions prior to 2026.2.22 fail to sanitize shell startup environment variables HOME and ZDOTDIR in the system.run function, allowing attackers to bypass command allowlist protections. Remote attackers can inject malicious startup files such as .bash_profile or .zshenv to achieve arbitrary code execution before allowlist-evaluated commands are executed.

CVSS: 7.5 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-03-21



CVE-2019-25568

Descripción: Memu Play 6.0.7 contains an insecure file permissions vulnerability that allows low-privilege users to escalate privileges by replacing the MemuService.exe executable. Attackers can rename and overwrite MemuService.exe in the installation directory with a malicious executable, which executes with system-level privileges when the service restarts after a computer reboot.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-03-21



CVE-2019-25614

Descripción: Free Float FTP 1.0 contains a buffer overflow vulnerability in the STOR command handler that allows remote attackers to execute arbitrary code by sending a crafted STOR request with an oversized payload. Attackers can authenticate with anonymous credentials and send a malicious STOR command containing 247 bytes of padding followed by a return address and shellcode to trigger code execution on t...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-787

Tecnología: No especificado

Publicado el: 2026-03-22



CVE-2026-4567

Descripción: A vulnerability has been found in Tenda A15 15.13.07.13. The impacted element is the function UploadCfg of the file /cgi-bin/UploadCfg. The manipulation of the argument File leads to stack-based buffer overflow. The attack may be initiated remotely. The exploit has been disclosed to the public and may be used.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-119

Tecnología: No especificado

Publicado el: 2026-03-23



CVE-2026-4600

Descripción: Versions of the package jsrsasign before 11.1.1 are vulnerable to Improper Verification of Cryptographic Signature via the DSA domain-parameter validation in KJUR.crypto.DSA.setPublic (and the related DSA/X509 verification flow in src/dsa-2.0.js). An attacker can forge DSA signatures or X.509 certificates that X509.verifySignature() accepts by supplying malicious domain parameters such as $g=1$, ...

CVSS: 7.4 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-347

Tecnología: No especificado

Publicado el: 2026-03-23



CVE-2026-4601

Descripción: Versions of the package jsrsasign before 11.1.1 are vulnerable to Missing Cryptographic Step via the `KJUR.crypto.DSA.signWithMessageHash` process in the DSA signing implementation. An attacker can recover the private key by forcing `r` or `s` to be zero, so the library emits an invalid signature without retrying, and then solves for `x` from the resulting signature.

CVSS: 8.7 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:C/C:H/I:H/A:N

Tipo: CWE-325

Tecnología: No especificado

Publicado el: 2026-03-23



CVE-2026-32968

Descripción: Due to the improper neutralisation of special elements used in an OS command, an unauthenticated remote attacker can exploit an RCE vulnerability in the com_mb24sysapi module, resulting in full system compromise. This vulnerability is a variant attack for CVE-2020-10383.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-03-23



CVE-2026-4585

Descripción: A vulnerability has been found in Tiandy Easy7 Integrated Management Platform up to 7.17.0. This vulnerability affects unknown code of the file `/Easy7/apps/WebService/ImportSystemConfiguration.jsp` of the component Configuration Handler. The manipulation of the argument File leads to os command injection. The attack can be initiated remotely. The exploit has been disclosed to the public and may ...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-03-23



CVE-2026-33297

Descripción: WWBN AVideo is an open source video platform. Prior to version 26.0, the `setPassword.json.php` endpoint in the CustomizeUser plugin allows administrators to set a channel password for any user. Due to a logic error in how the submitted password value is processed, any password containing non-numeric characters is silently coerced to the integer zero before being stored. This means that regardl...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-639

Tecnología: No especificado

Publicado el: 2026-03-23



CVE-2026-32913

Descripción: OpenClaw before 2026.3.7 contains an improper header validation vulnerability in fetchWithSsrFGuard that forwards custom authorization headers across cross-origin redirects. Attackers can trigger redirects to different origins to intercept sensitive headers like X-API-Key and Private-Token intended for the original destination.

CVSS: 9.3 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:L/A:N

Tipo: CWE-522

Tecnología: No especificado

Publicado el: 2026-03-23



CVE-2026-4001

Descripción: The Woocommerce Custom Product Addons Pro plugin for WordPress is vulnerable to Remote Code Execution in all versions up to, and including, 5.4.1 via the custom pricing formula `eval()` in the `process_custom_formula()` function within `includes/process/price.php`. This is due to insufficient sanitization and validation of user-submitted field values before passing them to PHP's `eval()` function. The ...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-95

Tecnología: No especificado

Publicado el: 2026-03-24



CVE-2026-4283

Descripción: The WP DSGVO Tools (GDPR) plugin for WordPress is vulnerable to unauthorized account destruction in all versions up to, and including, 3.1.38. This is due to the `super-unsubscribe` AJAX action accepting a `process\_now` parameter from unauthenticated users, which bypasses the intended email-confirmation flow and immediately triggers irreversible account anonymization. This makes it possible for...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Tipo: CWE-862

Tecnología: No especificado

Publicado el: 2026-03-24



CVE-2019-25628

Descripción: Download Accelerator Plus DAP 10.0.6.0 contains a structured exception handler buffer overflow vulnerability that allows remote attackers to execute arbitrary code by crafting malicious URLs. Attackers can create specially crafted URLs with overflowing buffer data that overwrites SEH pointers and executes embedded shellcode when imported through the application's web page import functionality.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-787

Tecnología: No especificado

Publicado el: 2026-03-24



CVE-2019-25646

Descripción: Tabs Mail Carrier 2.5.1 contains a buffer overflow vulnerability in the MAIL FROM SMTP command that allows remote attackers to execute arbitrary code by sending a crafted MAIL FROM parameter. Attackers can connect to the SMTP service on port 25 and send a malicious MAIL FROM command with an oversized buffer to overwrite the EIP register and execute a bind shell payload.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-787

Tecnología: No especificado

Publicado el: 2026-03-24



CVE-2025-71275

Descripción: Zimbra Collaboration Suite (ZCS) PostJournal service version 8.8.15 contains a command injection vulnerability that allows unauthenticated attackers to execute arbitrary system commands by exploiting improper sanitization of the RCPT TO parameter via SMTP injection. Attackers can inject shell expansion syntax through the RCPT TO parameter to achieve remote code execution under the Zimbra servic...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-03-24



Resumen del Reporte

CVEs analizados: 57

Promedio CVSS: 8.73

Fuente: nvd.nist.gov

Nos vemos la próxima semana. Hack the Cat ☹

